PROGRAMACIÓN III · TDS-007 · ITLA · 2026-C-3

Práctica 1 — Control de acceso completo

Bloque 2 | Semana 4 | 8 puntos | Individual

Primer hito de tu repositorio. Entregas la primera pieza del Core funcionando completa: **Control de acceso**, desde el registro con activación por correo hasta la recuperación de contraseña y la administración de usuarios, construida sobre el diseño de componentes de la semana 2 y con la mecánica de ramas y pull requests de la semana 3. Además dejas declarada la estructura de la máquina de estados de tu módulo de negocio, todavía sin pruebas.

> **Es la misma especificación para los 25.** Los identificadores de abajo son los de los *Requerimientos del Core*, pieza 1. Úsalos en tus commits y en la descripción de tus pull requests: un criterio de aceptación que no se cumple es un requisito que no está hecho, aunque el código corra.

1. Alcance

1.1 Registro y activación de la cuenta

ID	Requisito	Criterio de aceptación
RF-CA-01	Registro de usuario con correo único.	Un segundo registro con un correo ya existente se rechaza.
RF-CA-02	La contraseña se guarda con hash y sal, nunca en texto plano.	El valor almacenado no coincide con la contraseña y no puede revertirse a ella; dos usuarios con la misma contraseña no comparten el valor almacenado (RD-05).
RF-CA-14	Política mínima de contraseña: al menos 8 caracteres, con letras y números.	Una contraseña que no la cumple se rechaza con mensaje controlado, en el registro y en todo cambio de contraseña (RD-07).
RF-CA-15	El usuario nace inactivo y recibe por correo un enlace de activación con token de un solo uso y fecha de vencimiento.	Antes de activar, el inicio de sesión se rechaza con un mensaje que indica que la cuenta no está activa. El correo sale por la cola (RF-NOT-08).
RF-CA-16	Abrir el enlace activa la cuenta.	Tras activar, el inicio de sesión funciona. Usar el enlace dos veces, o después de vencido, se rechaza y el estado no cambia.
RF-CA-17	El usuario puede pedir que se le reenvíe el enlace de activación indicando su correo.	La respuesta es idéntica exista o no ese correo. El reenvío invalida el enlace anterior.

1.2 Sesión

ID	Requisito	Criterio de aceptación
RF-CA-03	Inicio de sesión que entrega una credencial de sesión.	Credenciales correctas abren sesión; incorrectas se rechazan sin revelar cuál de los dos datos falló.
RF-CA-07	Consulta del usuario autenticado y	Sin sesión válida la consulta se

	su rol.	rechaza.
RF-CA-18	Cierre de sesión.	La credencial cerrada deja de servir: usarla después se rechaza.
RF-CA-19	Tras 5 intentos fallidos consecutivos, la cuenta queda bloqueada 15 minutos.	El sexto intento, aun con la contraseña correcta, se rechaza durante el bloqueo. Un inicio de sesión correcto pone el contador en cero.

1.3 Roles y administración de usuarios

ID	Requisito	Criterio de aceptación
RF-CA-04	Dos roles: Administrador y Estándar.	Todo usuario tiene exactamente un rol asignado.
RF-CA-05	Cada operación del sistema declara qué rol puede ejecutarla.	Existe un punto del código donde se puede leer la exigencia de rol de cada operación.
RF-CA-06	Un usuario Estándar que invoca una operación de Administrador recibe un rechazo explícito.	El rechazo ocurre también cuando la petición se construye a mano, sin pasar por la interfaz (RD-06).
RF-CA-08	Cambio de rol de un usuario, reservado al Administrador.	Un Estándar no puede cambiar ningún rol, ni el propio.
RF-CA-20	Un Administrador desactiva y reactiva usuarios.	Un usuario desactivado no inicia sesión y sus sesiones abiertas dejan de ser válidas. Un Administrador no puede desactivarse a sí mismo.
RF-CA-21	Un Administrador lista los usuarios con su rol y su estado.	Un Estándar recibe rechazo. El listado nunca incluye hashes ni tokens.

1.4 Contraseñas: recuperación, cambio y restablecimiento

ID	Requisito	Criterio de aceptación
RF-CA-09	Un usuario inicia la recuperación de su contraseña indicando su correo registrado.	La respuesta es idéntica exista o no ese correo: el flujo no revela qué correos están registrados.
RF-CA-10	La recuperación genera un código de un solo uso con fecha de vencimiento y lo envía al correo del usuario a través de la cola de correos.	Usarlo dos veces, o después de vencido, se rechaza y la contraseña no cambia. El correo sale por la cola (RF-NOT-08).
RF-CA-11	Con un código válido el usuario define una contraseña nueva, que se guarda con hash.	La contraseña anterior deja de servir para iniciar sesión.
RF-CA-12	Las sesiones abiertas antes del cambio de contraseña dejan de ser válidas.	Una credencial de sesión emitida antes del restablecimiento es rechazada.
RF-CA-13	Un Administrador puede forzar el restablecimiento de la contraseña de un usuario.	El usuario no puede seguir usando su contraseña anterior y recibe por la cola el correo con el código para definir una nueva.

RF-CA-22	Un usuario con sesión cambia su propia contraseña indicando la actual.	Con la contraseña actual incorrecta el cambio se rechaza. Al cambiarla aplican RF-CA-14 y RF-CA-12.

1.5 Correo saliente: la cola mínima

Activación, recuperación y restablecimiento forzado envían correos. Desde esta práctica el correo no se envía dentro de la operación que lo origina: se registra en la entidad `CorreoEnCola` y un proceso aparte lo envía (RF-NOT-08 y RF-NOT-09, versión mínima). Lo que se exige ahora:

- La operación de negocio termina bien aunque el servidor de correo no responda; el correo queda en la cola en estado pendiente.
- Un proceso o comando independiente toma los pendientes, los envía por SMTP y los marca como enviados. Ejecutarlo dos veces no duplica envíos (RF-NOT-12).
- Las credenciales del servidor SMTP se leen de variables de entorno (RF-NOT-13, RD-10). Sirve cualquier servidor al que tengas acceso: el de tu correo personal con una contraseña de aplicación, o un servicio de pruebas.
- El correo se recibe de verdad: al calificar me registro con mi propio correo y abro el enlace.

Reintentos, estado fallido, último error y consulta de la cola por el Administrador llegan en la semana 11, con la pieza 4.

Aplican además los requisitos de diseño que tocan esta pieza: RD-05, RD-06, RD-07 (un correo vacío o mal formado produce un rechazo controlado, no una excepción sin manejar), RD-08 (ningún mensaje al usuario expone trazas ni consultas), RD-09 (los usuarios registrados sobreviven a reiniciar la aplicación) y RD-10. Los registros de auditoría de RF-CA-08, RF-CA-13 y RF-CA-20 se exigen en la semana 14, con la pieza 6; aquí no se califican.

1.6 Estructura de tu máquina de estados de negocio

Sin pruebas todavía; eso llega en la semana 8. Lo que se entrega es la estructura:

- La entidad central de tu dominio existe en el modelo de datos, con su atributo de estado.
- Los estados están declarados en un solo lugar del código (RF-NEG-03), entre 3 y 5.
- Las transiciones permitidas están declaradas en un solo lugar (RD-04), con al menos una transición prohibida explícita (RF-NEG-04) y al menos un estado terminal (RF-NEG-05).
- Un archivo `docs/maquina-de-estados.md` con la tabla de transiciones: desde, hacia, quién la ejecuta, condición. Igual que la tabla de Gestión de permisos de los Requerimientos del Core.

1.7 Cómo se construyó: historial y pull requests

- Cada funcionalidad en su rama, fusionada a `main` por un pull request en tu propio repositorio con las cuatro secciones: Qué cambia, Por qué, Cómo probarlo, Qué NO incluye. Como mínimo cuatro pull requests: registro y activación, sesión, recuperación de contraseña, administración de usuarios.
- Commits atómicos con asunto en imperativo y el identificador del requisito que cubren.
- README con las instrucciones exactas para ejecutar el proyecto, las variables de entorno que necesita (nombre y para qué, nunca el valor) y cómo provocar cada criterio de aceptación. Se sigue al pie de la letra al calificar; lo que el README no dice, no se busca.

2. Cómo se entrega

```
git tag practica-1
git push origin --tags
```

En Moodle, en la tarea «Práctica 1»: la URL de tu repositorio y el nombre de la etiqueta. Se evalúa el punto etiquetado; puedes seguir trabajando en `main` después.

3. Rúbrica

Criterio	No logrado (0 %)	Parcialmente logrado (50 %)	Logrado (100 %)
Registro y activación RF-CA-01, 02, 14, 15, 16, 17 (1.5 pts)	No se puede registrar un usuario, o la contraseña se guarda en texto plano, o la cuenta funciona sin activar.	Registro con hash y activación por enlace funcionan, pero falla uno de estos: correo duplicado aceptado, hash sin sal, enlace reutilizable o sin vencimiento, política de contraseña ausente, reenvío que revela si el correo existe.	Registro con correo único, hash con sal, política de contraseña, cuenta inactiva hasta abrir el enlace, enlace de un solo uso con vencimiento, y reenvío con respuesta idéntica exista o no el correo.
Sesión RF-CA-03, 07, 18, 19 (1.5 pts)	No hay inicio de sesión, o acepta credenciales incorrectas, o no entrega credencial de sesión.	Inicio de sesión funciona, pero falla uno de estos: el rechazo revela qué dato falló, la consulta del autenticado responde sin sesión, no hay cierre de sesión efectivo, no hay bloqueo por intentos.	Credenciales incorrectas rechazadas con el mismo mensaje, consulta del autenticado protegida, cierre de sesión que invalida la credencial, y bloqueo temporal tras cinco fallos consecutivos.
Roles y administración RF-CA-04, 05, 06, 08, 20, 21, RD-06 (1.5 pts)	No hay roles, o cualquier usuario puede ejecutar cualquier operación.	Roles y rechazo funcionan desde la interfaz, pero una petición construida a mano por un Estándar se ejecuta, o la exigencia de rol está repetida en varios lugares, o falta el cambio de rol, la desactivación o el listado.	Exigencia de rol legible en un punto, rechazo del lado del servidor aunque la petición se construya a mano, cambio de rol y desactivación reservados al Administrador con sus protecciones, y listado sin datos sensibles.
Contraseñas RF-CA-09 a 13, 22 (1.5 pts)	No hay recuperación de contraseña, o el código no vence ni es de un solo uso, o la contraseña anterior sigue sirviendo.	La recuperación funciona, pero falla uno de estos: el flujo revela qué correos existen, las sesiones anteriores siguen válidas, falta el restablecimiento forzado por Administrador, o el cambio con sesión no exige la contraseña actual.	Recuperación con código de un solo uso y vencimiento, respuesta idéntica exista o no el correo, sesiones anteriores invalidadas, restablecimiento forzado por Administrador, y cambio de contraseña con sesión que exige la actual.
Correo por cola RF-NOT-08, 09, 12, 13 (0.5 pt)	El correo se envía dentro de la operación, o hay credenciales SMTP en el repositorio, o el correo no llega.	Se encola y se envía, pero ejecutar el enviador dos veces duplica envíos, o la operación falla cuando el servidor SMTP no responde.	La operación termina bien sin servidor SMTP, el enviador independiente entrega el correo real, no duplica envíos, y las credenciales vienen de variables de entorno.

Máquina de estados de negocio RF-NEG-03, 04, 05, RD-04 (0.5 pt)	No existe la entidad central con estado, o los estados no están declarados en ningún lugar del código.	Entidad y estados declarados, pero las transiciones no están en un solo lugar, o falta la transición prohibida o el estado terminal, o falta la tabla en `docs/`.	Entidad con estado, entre 3 y 5 estados en un solo lugar, transiciones en un solo lugar con al menos una prohibida y un estado terminal, y la tabla documentada.
Historial, pull requests y README (1.0 pt)	Trabajo directo en `main` sin ramas ni pull requests, o credenciales o archivos generados en el historial, o el README no permite ejecutar el proyecto.	Hay ramas y pull requests, pero alguna descripción no trae las cuatro secciones, o hay commits que mezclan cambios sin relación, o el README omite variables de entorno o cómo provocar algún criterio.	Al menos cuatro pull requests con las cuatro secciones, commits atómicos que citan el requisito, nada indebido en el historial, y un README que permite ejecutar y verificar cada criterio sin preguntar.
Total	8.0		

> ⚠ **Revisión acumulada.** A partir de la Práctica 2, dos de los ocho puntos de cada práctica verifican que lo entregado aquí siga funcionando: registro con activación, inicio de sesión, rechazo por rol y recuperación de contraseña. Romper Control de acceso en la semana 5 cuesta puntos en las semanas 7, 8 y 11.

4. Qué se revisa exactamente

- `git clone`, `git checkout practica-1`, variables de entorno según el README, y ejecución.
- Registrarme con mi propio correo; intentar iniciar sesión antes de activar; abrir el enlace recibido; abrirlo por segunda vez; intentar registrar el mismo correo otra vez.
- Registrar con una contraseña de 5 caracteres y con un correo mal formado: rechazo controlado.
- Leer el almacenamiento: la contraseña no aparece; dos usuarios con la misma contraseña no comparten el valor almacenado.
- Iniciar sesión con contraseña incorrecta y con correo inexistente: los dos rechazos son idénticos. Fallar cinco veces seguidas y luego usar la contraseña correcta.
- Cerrar sesión y volver a usar la credencial cerrada.
- Con sesión de Estándar, invocar una operación de Administrador construyendo la petición a mano; intentar cambiar mi propio rol.
- Como Administrador: listar usuarios, cambiar un rol, desactivar un usuario con sesión abierta y probar esa sesión, intentar desactivarme a mí mismo.
- Pedir recuperación con un correo inexistente y con uno existente: misma respuesta. Usar el código, volver a usarlo, iniciar sesión con la contraseña vieja y con la nueva, probar una credencial emitida antes del cambio.
- Forzar el restablecimiento de un usuario como Administrador. Cambiar mi contraseña con sesión indicando una contraseña actual incorrecta.
- Apagar el acceso al servidor SMTP y registrar un usuario: la operación termina bien y el correo queda pendiente. Ejecutar el enviador dos veces.
- Reiniciar la aplicación: los usuarios siguen ahí.
- Localizar el punto único de estados y transiciones del negocio, y leer `docs/maquina-de-estados.md`.

- `git log --oneline --graph --all`, `git ls-files` y `git log -p` en busca de credenciales; los pull requests en GitHub.